

被Git打破的 企業安全大門

2015.11 by phithon

Who am I

- **phith0n**
- 乌云核心白帽子/XDSEC成员
- 从事Web安全/运维安全研究

What is GIT

```
SAPI_API SAPI_POST_HANDLER_FUNC(rfc1867_post_handler) /* {{{ */
{
    char boundary, s = NULL, boundary_end = NULL, start_arr = NULL, *array_index = NULL;
    char temp_filename = NULL, lbuf = NULL, *abuf = NULL;
    int boundary_len = 0, cancel_upload = 0, is_arrupload = 0, arraylen = 0;
    int64_t total_bytes = 0, max_file_size = 0;
    int skip_upload = 0, anonindex = 0, *is_anonymous;
    zval *http_post_files = NULL;
    HashTable *uploaded_files = NULL;
    multipart_buffer *mbuff;
    zval array_ptr = (zval ) arg;
    int fd = -1;
    int upload_cnt = INI_INT("max_file_uploads");
    const zend_encoding internal_encoding = zend_multibyte_get_internal_encoding(TSRMLS_C);
    php_rfc1867_getword_t getword;
    php_rfc1867_getword_conf_t getword_conf;
    php_rfc1867_basename_t _basename;
```

```
SAPI_API SAPI_POST_HANDLER_FUNC(rfc1867_post_handler) /* {{{ */
{
    char boundary, s = NULL, boundary_end = NULL, start_arr = NULL, *array_index = NULL;
    char temp_filename = NULL, lbuf = NULL, *abuf = NULL;
    int boundary_len = 0, cancel_upload = 0, is_arrupload = 0, arraylen = 0;
    int64_t total_bytes = 0, max_file_size = 0;
    int skip_upload = 0, anonindex = 0, *is_anonymous;
    zval *http_post_files = NULL;
    HashTable *uploaded_files = NULL;
    multipart_buffer *mbuff;
    zval array_ptr = (zval) arg;
    int fd = -1;
    int upload_cnt = INI_INT("max_file_uploads");
    const zend_encoding internal_encoding = zend_multibyte_get_internal_encoding(TSRMLS_C);
    php_rfc1867_getword_t getword;
    php_rfc1867_getword_conf_t getword_conf;
    php_rfc1867_basename_t basename;
    if (php_rfc1867_encoding_translation(TSRMLS_C) && internal_encoding) {
        getword = php_rfc1867_getword;
        getword_conf = php_rfc1867_getword_conf;
        basename = php_rfc1867_basename;
    } else {
        getword = php_ap_getword;
        getword_conf = php_ap_getword_conf;
    }
}
```

删除

增加

```
SAPI_API SAPI_POST_HANDLER_FUNC(rfc1867_post_handler) /* {{{ */
{
    char boundary, s = NULL, boundary_end = NULL, start_arr = NULL, *array_index = NULL;
    char temp_filename = NULL, lbuf = NULL, *abuf = NULL;
    int boundary_len = 0, cancel_upload = 0, is_arrupload = 0, arraylen = 0;
    int64_t total_bytes = 0, max_file_size = 0;
    int skip_upload = 0, anonindex = 0, *is_anonymous;
    int upload_cnt = INI_INT("max_file_uploads");
    const zend_encoding internal_encoding = zend_multibyte_get_internal_encoding(TSRMLS_C);
    php_rfc1867_getword_t getword;
    php_rfc1867_getword_conf_t getword_conf;
    php_rfc1867_basename_t basename;
    if (php_rfc1867_encoding_translation(TSRMLS_C) && internal_encoding) {
        getword = php_rfc1867_getword;
        getword_conf = php_rfc1867_getword_conf;
        basename = phprfc1867_basename;
    } else {
        getword = php_ap_getword;
        getword_conf = php_ap_getword_conf;
    }
}
```

增加


```
SAPI_API SAPI_POST_HANDLER_FUNC(rfc1867_post_handler) /* {{{ */
{
    char boundary, s = NULL, boundary_end = NULL, start_arr = NULL, *array_index = NULL;
    char temp_filename = NULL, lbuf = NULL, *abuf = NULL;
    int boundary_len = 0, cancel_upload = 0, is_arrupload = 0, arraylen = 0;
    int64_t total_bytes = 0, max_file_size = 0;
    int skip_upload = 0, anonindex = 0, *is_anonymous;
    int upload_cnt = INI_INT("max_file_uploads");
    const zend_encoding internal_encoding = zend_multibyte_get_internal_encoding(TSRMLS_C);
    php_rfc1867_getword_t getword;
    php_rfc1867_getword_conf_t getword_conf;
    php_rfc1867_basename_t _basename;
    if (php_rfc1867_encoding_translation(TSRMLS_C) && internal_encoding) {
        getword = php_rfc1867_getword;
        getword_conf = php_rfc1867_getword_conf;
        basename = phprfc1867_basename;
    } else {
        getword = php_ap_getword;
        getword_conf = php_ap_getword_conf;
    }
}
```

Finish

phithon@fake-demo:~\$ git add .

phithon@fake-demo:~\$ git commit

Git是一个分布式版本控制软件
在开发中运用**git**可以方便地进行团队协作、敏捷开发



GIT与信息安全

- Github造成的企业敏感信息泄露
- web目录/.git/访问造成的源码泄露
- 内网Git未授权访问造成敏感信息泄露

- **Github**造成的企业敏感信息泄露
- web目录/.git/访问造成的源码泄露
- 内网Git未授权访问造成敏感信息泄露

当最單純的人遇上了最邪惡的人



案例 / 某电商宁手机客户端源码泄露

SuningEBuy/AppDelegate.svn/text-base/PasswdUtil.h.svn-base

Showing the top three matches. Last indexed a day ago.

```
14 // 需要和服务端保持一致
15 #define kPBEDefaultSalt 
16
17
18 @interface PasswdUtil : NSObject
19
20 /*!
21  * @abstract
22  ...
23
24 //刘坤添加，可设盐的
25 + (NSString *)encryptString:(NSString *)string forKey:(NSString *)key salt:(NSString
26 *)salt;
27
28 *)salt?
29 + (NSString *)encryptString:(NSString *)string forKey:(NSString *)key salt:(NSString
30 *)salt;
31
32 //刘坤添加，可设盐的
33 ...
34
```

案例 / 某电商宝内网邮箱泄露导致漫游

<http://www.wooyun.org/bugs/wooyun-2014-062243>

简要描述：

能给任意支付宝账号充值

最终导致后果

详细说明：

#1 账号泄露

<https://github.com/zengjianjay/anzycg/blob/1cae1988a2dd0f5dce6ce815529030ce122ed4bc/config/application.rb>

code 区域

```
ActionMailer::Base.smtp_settings = {  
  
  :address => 'smtp.alibaba-inc.com',  
  
  :domain => 'alibaba-inc.com',  
  
  :port => 465,  
  
  :user_name=> "kelude@taobao.com",  
  :password => "Hello@1234",  
  
  :authentication => :login,  
  
  :enable_starttls_auto => true  
  
}
```

重要职工信息：内网邮箱、密码

Github Hacking Skill

- 关键词搜索: **password**、**@domain.com**、**salt**、**BEGIN RSA PRIVATE KEY**、**smtp**
- “**@domain-inc.com** in:file” 在所有代码中搜索内网邮箱
- “**id_rsa** in:path” 获得结果18534个
- “**password** language:yaml” 获得结果784327个
- “**password** size:<100 language:php” 利用常见情况搜索
- “**smtp** file:config extension:php” 组合条件搜索
- “**include(\$_GET[]);**” 搜索可能存在任意文件包含漏洞的代码

.ssh/id_rsa in:path

We've found 378 code results



foalish/Dads_vision – key

Last indexed on 1 Jun.



.ssh / id_rsa /key



foalish/Dads_vision – key.pub

Last indexed on 1 Jun.



.ssh / id_rsa /key.pub



tsara27/sample_app – ssh-add id_rsa

Last indexed on 1 Jun.



ssh-add id_rsa



zobront/picaday – ssh-add id_rsa

Last indexed on 1 Jun.



ssh-add id_rsa



ArtCrOm/ArtFav – ssh-add id_rsa

Last indexed on 1 Jun.



ssh-add id_rsa



ssh-add id_rsa



Last indexed on 1 Jun.

ArtCrOm/ArtFav – ssh-add id_rsa

phpteam01/lawyer – mail.php

PHP

Showing the top 12 matches. Last indexed on 30 May.

```
$config['charset'] = 'UTF-8';
$config['smtp_host'] = 'smtp.gmail.com';
$config['smtp_secure'] = 'ssl';
$config['smtp_auth'] = TRUE;

$config['smtp_username'] = 'noreply@michaelmartinesq.com';
$config['smtp_password'] = '1password1';
$config['smtp_debug'] = FALSE;

/* End of file mail.php */
```

yibmsd/xiaolu – email.php

PHP

Showing the top nine matches. Last indexed on 6 Jun.

```
$config['protocol'] = 'smtp';
$config['smtp_host'] = 'smtp.126.com';
$config['smtp_user'] = 'angel836@126.com';
$config['smtp_pass'] = 'wanghaibing836';
$config['mailtype'] = 'html';

/* End of file music.php */
/* Location: ./application/controllers/music.php */
```



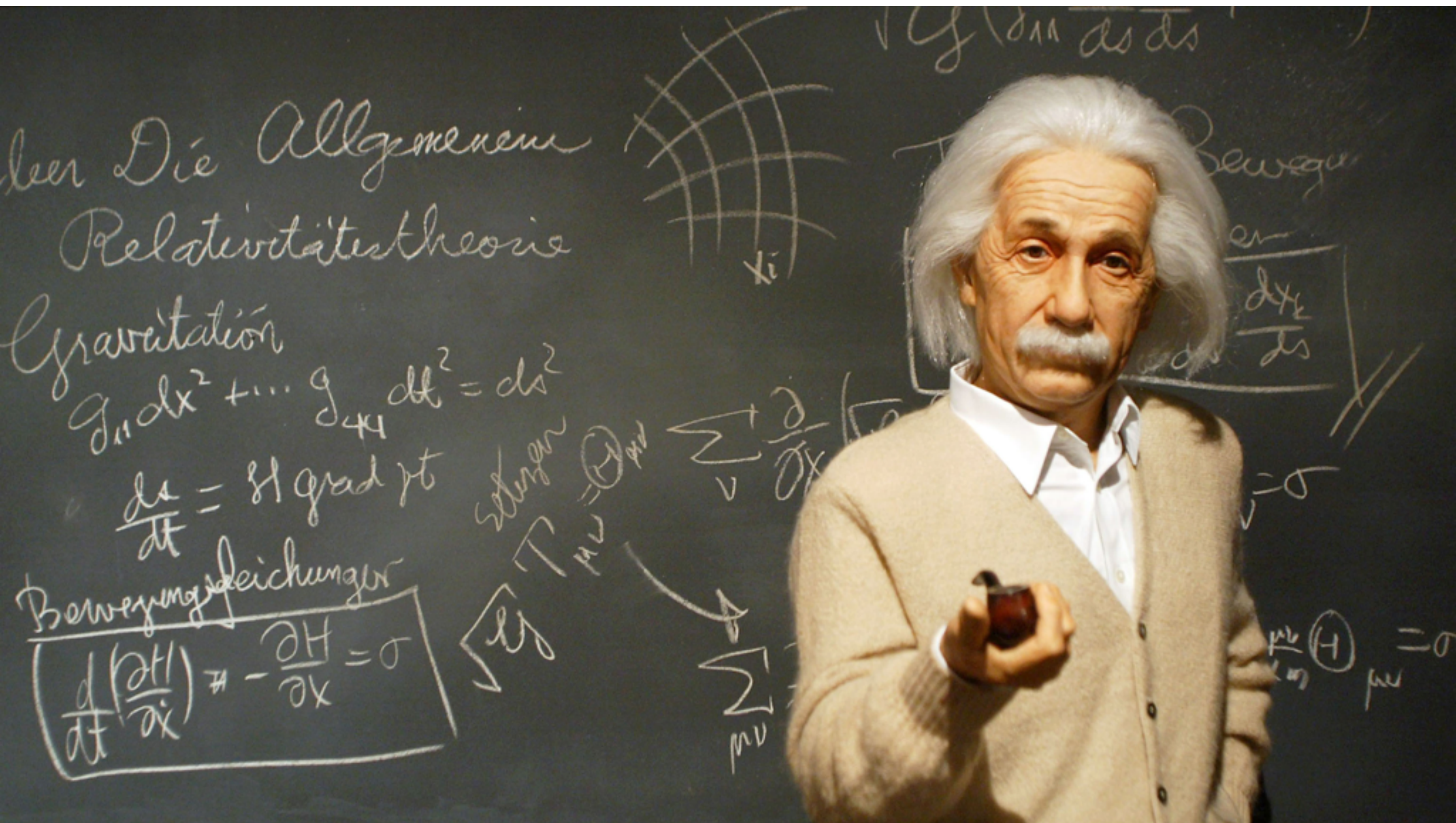
容我吃包辣条冷静一下
容我吃包辣条冷静一下

- 开源诚可贵，安全价更高
- 对密码的敏感性
- .gitignore的重要性！！

- **Github**造成的企业敏感信息泄露
- web目录/.git/访问造成的源码泄露
- 内网Git未授权访问造成敏感信息泄露

- Github造成的企业敏感信息泄露
- **web目录/.git/访问造成的源码泄露**
- 内网Git未授权访问造成敏感信息泄露

从GIT原理講起



“为什么我们能够从泄露的.git目录还原出网站源码？”

git init

1、创建.git目录

2、初始化.git目录，写入config等文件

git add .

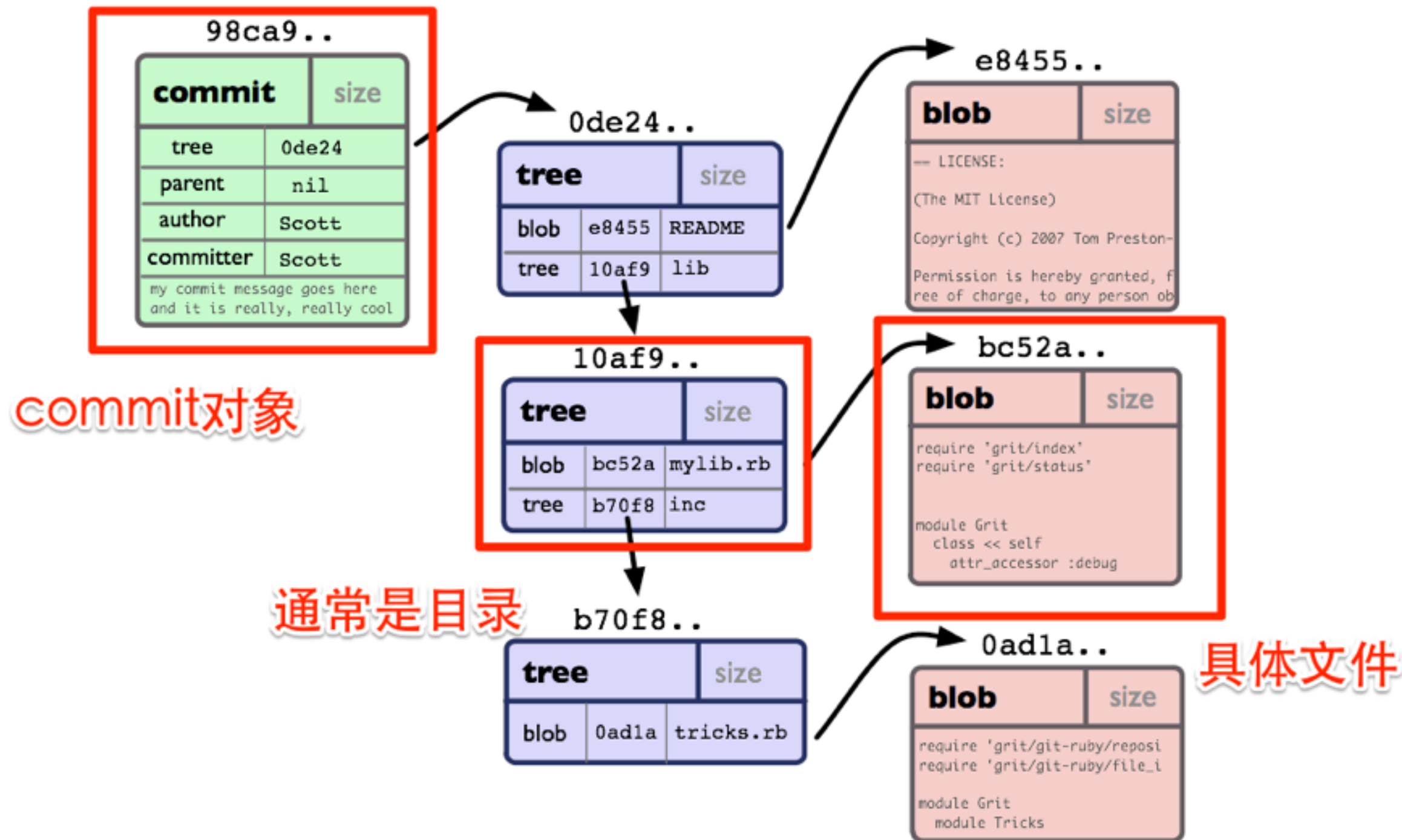
3、为每一个改动的文件（目录）创建git object

git commit

4、建立commit类型objects

5、更新HEAD指向的revision

git objects文件格式



git objects文件格式

blob

blob 25\x00This is the README file.\n

tree

tree 192\0

40000 admin\0 a84943494657751ce187be401d6bf59ef7a2583c

40000 static\0 14f589a30cf4bd0ce2d7103aa7186abe0167427f

40000 core\0 ec559319a263bc7b476e5f01dd2578f255d734fd

100644 index.php\0 97e5b6b292d248869780d7b0c65834bfb645e32a

40000 application\0 6e63db37acba41266493ba8fb68c76f83f1bc9dd

git objects還原

方法1、

读取并解析.git/index，依次下载所有文件

方法2、

读取并解析objects，从blob中提取源文件

最優

方法3、

解析并依次下载objects，执行git reset还原源文件

方法3、

解析并依次下载objects，执行git reset还原源文件

```
git ls-tree <revision>
```

列出tree对象的所有子对象

```
git cat-file -p <revision>
```

列出blob对象的内容

```
git reset
```

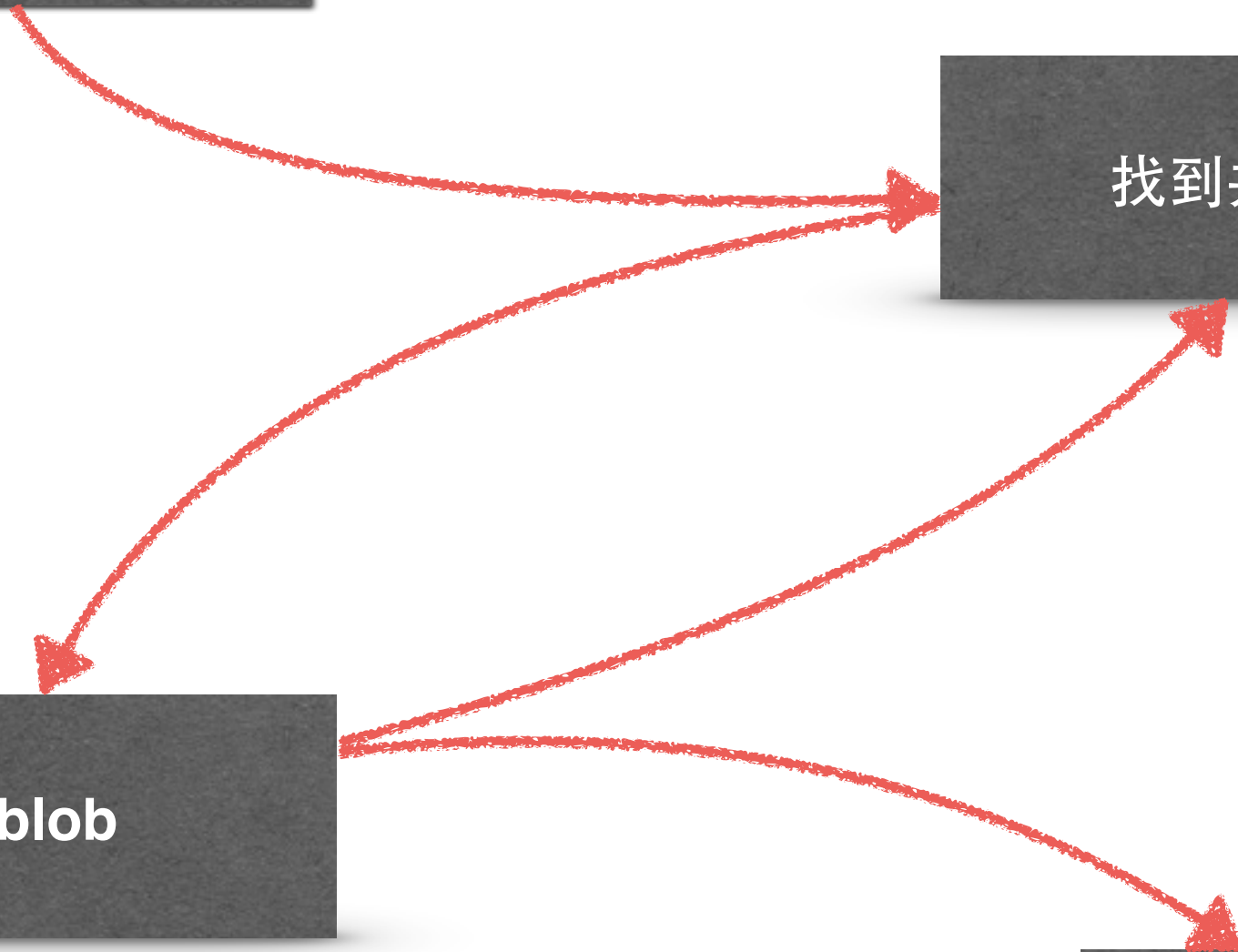
还原整个GIT环境（较其他两法的优势）

找到commit id

找到并下载tree

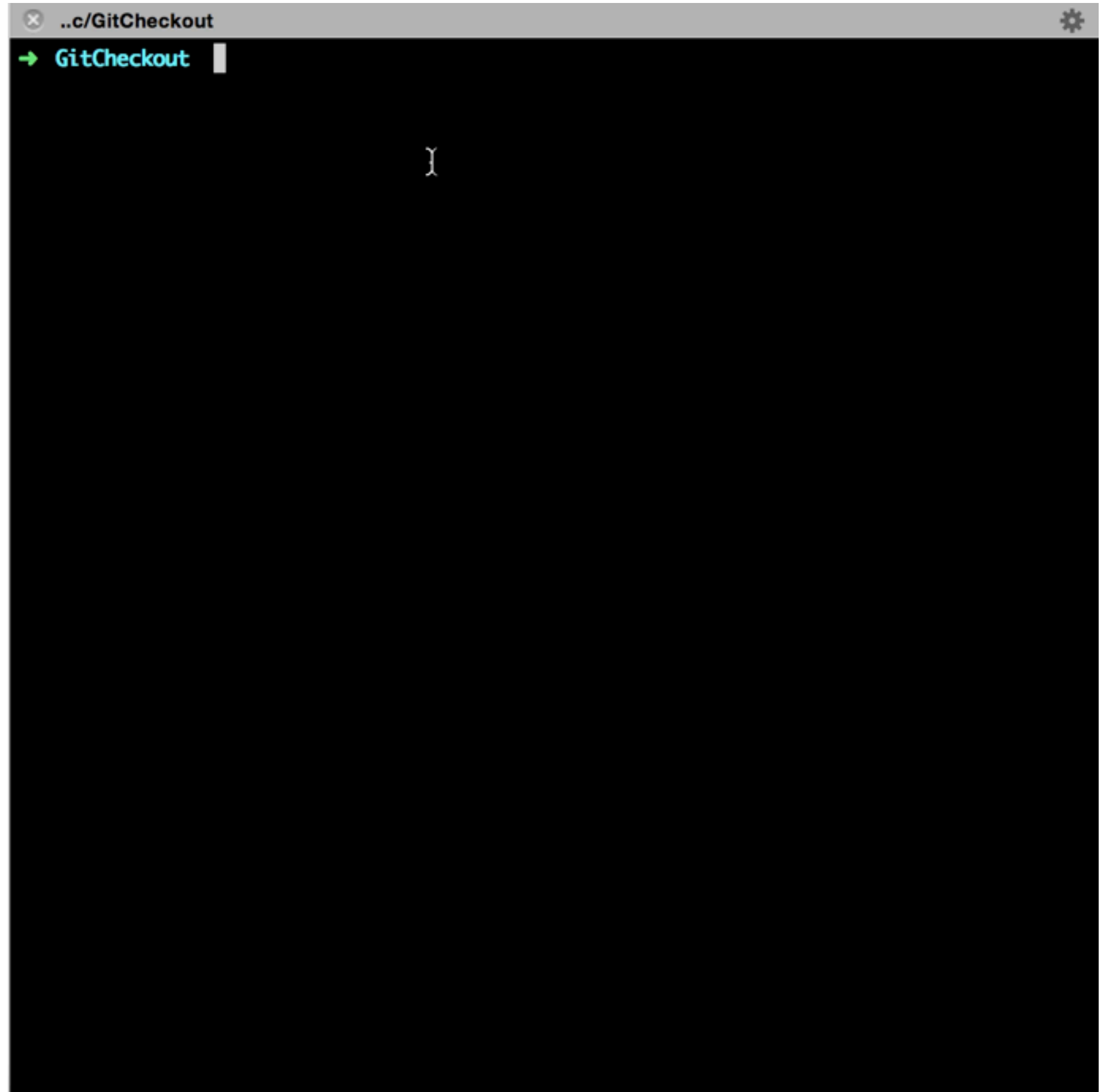
下载blob

git reset
恢复源文件



GitRefs 运行演示

[http://v.qq.com/
page/y/e/l/
y0171fyrxel.htm](http://v.qq.com/page/y/e/l/y0171fyrxel.htm)
!



案例

- **WooYun-2015-133666** 百度某站漏洞导致敏感信息泄露Getshell(涉及至少66W+的用户数据含密码可内网)
- **WooYun-2015-121319** PHP官方多个分站存在git信息泄露可读取大量程序源码
- **WooYun-2015-117925** 盛大某站源码泄露Getshell直入内网
- **WooYun-2015-114272** 百度从git信息泄露到getshell漫游内网
- **WooYun-2015-93434** 我是如何让周鸿祎/王思聪等关注我微博的



思考

如何直接利用git自带命令下载泄露的源码?

提示

git clone的工作流程
http协议的git服务器原理

- Github造成的企业敏感信息泄露
- **web目录/.git/访问造成的源码泄露**
- 内网Git未授权访问造成敏感信息泄露

- Github造成的企业敏感信息泄露
- web目录/.git/访问造成的源码泄露
- 内网**Git**未授权访问造成敏感信息泄露

GIT

私有化解决方案



Gogs

A painless self-hosted Git service.



Gitlab

- 1.服务器存在于内网，代码绝对私有性可受保障
- 2.稳定性不受平台影响
- 3.内网速度快，便于加速团队内部敏捷开发
- 4.便于二次开发，可兼容公司内部认证机制，避免冗余的认证操作
- 5.公司对平台拥有绝对控制权，避免出现不必要的纠纷



Github

- 1.具有成熟的技术支持，减少环境、运维、迭代的支出
- 2.具有更加成熟的安全性



私有化GIT解決方案安全性問題

- 黑客进入内网后，GIT又暴露出哪些问题？
 - GIT服务权限配置不当
 - Gitlab等开源项目的不稳定性
 - Gitweb的滥用与漏洞

GIT服務的載體

特点与利用

FILE协议

优点：利用文件系统进行权限限制。
缺点：只允许本地或共享硬盘访问。

SSH协议

优点：基于SSH协议的通用性与安全性。
缺点：权限限制太死，不适合开源软件。

GIT协议

监听9418端口
优点：速度快
缺点：没有授权机制，传输过程也不加密

HTTP(S)协议

优点：适用性广，服务器搭建简单
缺点：传输数据过大，且无权限控制

GIT服務權限配置不當

- GIT服务端权限设置不合理
- 影响协议方式：GIT协议、HTTP(S)协议
- 利用：
 - 下载内部项目 `git clone git://xxx.com/private/project.git`
 - 写入任意文件 `git push git://xxx.com/private/project.git`
- 解决方案：公有/私有项目严格划分，用ssh进行身份认证

Gitlab等開源項目的不穩定性

- 平台易受到传统WEB漏洞影响
- **CVE-2014-6271** shellshock漏洞导致的gitlab任意命令执行漏洞
- **CVE-2013-4580** GitLab未经身份验证API访问漏洞
- **CNVD-2013-14288** GitLab 'SSH key upload'功能远程执行代码漏洞
- 解决方案：及时更新/跟进

Gitweb的濫用与漏洞

- gitweb是git自带的web界面（默认端口1234）：
- `git instaweb —httpd=lighttpd`

The screenshot displays the Gitweb interface for a repository named 'projects / .git / summary'. The interface includes a navigation bar with links for 'summary', 'shortlog', 'log', 'commit', 'commitdiff', and 'tree'. A search bar is located on the right. The main content area shows repository metadata: 'description: Unnamed repository; edit this file 'description' to name the repository.', 'owner: 时雨', and 'last change: Thu, 20 Aug 2015 10:15:44 +0800 (10:15 +0800)'. Below this is a 'shortlog' section listing recent commits. Each commit entry includes the date, author, commit message, and links for 'commit', 'commitdiff', 'tree', and 'snapshot'. The 'master' branch is highlighted in green. At the bottom, the 'heads' section shows the 'master' branch, with a '2 months ago' timestamp and links for 'shortlog', 'log', and 'tree'.

projects / .git / summary 

summary | [shortlog](#) | [log](#) | [commit](#) | [commitdiff](#) | [tree](#) ? search: ☐ re

description Unnamed repository; edit this file 'description' to name the repository.
owner 时雨
last change Thu, 20 Aug 2015 10:15:44 +0800 (10:15 +0800)

shortlog

2015-08-20	phithOn	修改py2.6不支持delta_seconds的问题	master	origin/master	commit	commitdiff	tree	snapshot
2015-08-20	phithOn	修改README.md格式			commit	commitdiff	tree	snapshot
2015-08-20	phithOn	增加选项: 指定配置文件路径			commit	commitdiff	tree	snapshot
2015-08-20	phithOn	修改几个文档错误			commit	commitdiff	tree	snapshot
2015-06-08	phithOn	修改协议			commit	commitdiff	tree	snapshot
2015-06-03	时雨	修复关闭评论验证码时抛出异常的错误			commit	commitdiff	tree	snapshot
2015-05-31	时雨	调整默认头像			commit	commitdiff	tree	snapshot
2015-05-18	时雨	后台“增加板块”功能			commit	commitdiff	tree	snapshot
2015-05-18	时雨	后台“增加板块”功能			commit	commitdiff	tree	snapshot
2015-05-13	时雨	增加管理员初始化脚本			commit	commitdiff	tree	snapshot
2015-05-13	时雨	增加管理员初始化脚本			commit	commitdiff	tree	snapshot
2015-05-11	时雨	空格全换为缩进			commit	commitdiff	tree	snapshot
2015-05-11	时雨	修复分页函数一处BUG			commit	commitdiff	tree	snapshot
2015-05-10	时雨	根据编辑器情况修改html过滤白名单			commit	commitdiff	tree	snapshot
2015-05-10	时雨	正确处理缩进			commit	commitdiff	tree	snapshot
2015-05-10	时雨	为simditor增加上传功能			commit	commitdiff	tree	snapshot

...

heads

2 months ago [master](#) [shortlog](#) | [log](#) | [tree](#)

Gitweb的濫用与漏洞

- Gitweb远程命令执行漏洞演示（CVE-2008-5516）
- <http://v.qq.com/page/r/z/l/r0171uj9jzl.html>

```
root@9dc08befe3f8:~/git-skill#
```

GIT对于后渗透 的价值

- 源码审计
- 信息收集
- 内网渗透



GIT对于后渗透的价值

- 源码审计
- 信息收集
 - `git blame filename` 查看代码每一行的作者
 - `git log | grep ".*@.*" | sort -u | uniq` 找到所有开发者及其邮箱地址
 -
- 内网渗透

开发者：GIT是一个好用的版本控制软件

What is GIT

hacker：GIT是一个信息的大宝库

END

Email: root@leavesongs.com

weibo: @phithon别跟路人甲BB

blog: <http://www.leavesongs.com/>